

Gestion des utilisateurs et droits d'accès (PHP / MySQL)

1) Objectifs et Prérequis	1
2) Étapes de réalisation	1
3) Conclusion	3

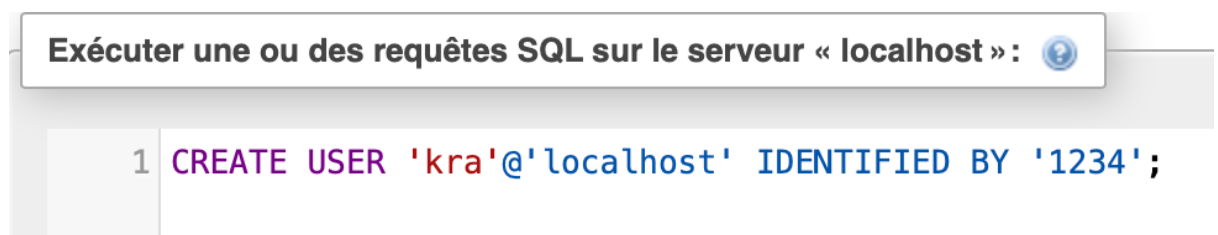
1) Objectifs et Prérequis

L'objectif de ce TP est de mettre en pratique la sécurisation d'une base de données en gérant la création d'utilisateurs et l'attribution de privilèges spécifiques lors de l'interaction avec un script PHP. Comme prérequis, il est nécessaire de disposer d'une page PHP fonctionnelle capable de se connecter à une base de données et d'afficher le contenu d'une table.

2) Étapes de réalisation

Etape 1 à 3 : Création de l'utilisateur et test de connexion

- Action : Création d'un nouvel utilisateur MySQL restreint à un accès local depuis l'interface phpMyAdmin.



- Modification du script : Remplacement de l'identifiant administrateur 'root' par le nouvel utilisateur dans la fonction mysqli_connect.

```
<?php    Add a new line at the end of this file.
if($bdd = mysqli_connect('localhost', 'kra', '1234', 'dossier 3.4'))
{
    $sql = "SELECT * FROM `client`";
    $result = mysqli_query($bdd, $sql);
```

Lorsque l'on exécute la page dans notre navigateur, la page n'affiche pas les clients.

Explication de l'erreur : L'exécution génère une erreur d'accès (Access denied). Par défaut, un nouvel utilisateur n'a absolument aucun droit sur la base de données. Il ne peut même pas lire la table client

Access Denied

You don't have permission to access "http://localhost/dossier 3;4" on this server.

Etape 4 et 5: Attribution des droits de lecture

Action : Attribution des droits de lecture (SELECT) à l'utilisateur spécifiquement sur la table client.

```
1 GRANT SELECT ON `dossier 3.4`.`client` TO 'kra'@'localhost';
```

Résultat : Lors de la réexécution, le message d'erreur disparaît et les données s'affichent correctement.

Etape 6 : Test des limites et droits d'écriture

Désormais, nous testons les limites des privilèges en tentant une insertion de données.

- **Action** : Ajout d'une requête d'insertion (INSERT INTO) dans le code PHP.

```
$requeteInsert = "INSERT INTO `client` (nom, prenom) VALUES ('Dupont', 'Jean')";
$resultatInsert = mysqli_query($bdd, $requeteInsert);
```

- Explication de l'erreur : L'insertion ne fonctionne pas et affiche une erreur du type INSERT command denied. La raison est logique : à l'étape 4, on a donné le droit de lecture (SELECT) à l'utilisateur, mais on ne lui a pas donné le droit d'écriture (INSERT). Il est donc bloqué
- **Résolution** : Attribution des droits d'insertion via une nouvelle requête GRANT.

```
1 GRANT INSERT ON `dossier 3.4`.`client` TO 'kra'@'localhost';
```

Matisse kra

bts sio

3) Conclusion

Ce TP met en évidence le principe de sécurité du "moindre privilège". Une application ne doit pas utiliser un compte administrateur ('root') pour interagir avec une base de données. Il est indispensable de créer des utilisateurs dédiés et de leur attribuer uniquement les droits stricts nécessaires (SELECT, INSERT) à leur fonctionnement.